

CYBERSECURITY PROJECT — CS-02

Web Application Security Assessment Using OWASP Methodology

Student Group Project Submission Document

Group: 02

Project Code: CS-02

Student 1 Name: _____

Student 2 Name: _____

Student 3 Name: _____

College: _____

Internship institution _____

Project Guide: _____

Date of Submission: _____

1. Project Overview

Web applications are a major component of modern information systems. They commonly handle authentication, user information, business processes, databases, and other sensitive operations.

A web application may be exposed to security risks because of insecure application logic, improper access control, weak authentication, insecure configuration, inadequate input validation, or vulnerable software components.

This project requires the student group to build or deploy an **intentionally vulnerable web application in an isolated laboratory environment** and perform a structured security assessment.

The recommended application is **OWASP Juice Shop**. Alternatives such as DVWA or WebGoat may be used with instructor approval.

The project will focus on identifying, documenting, analyzing, and where practical remediating web-application security weaknesses.

The project must follow this lifecycle:

Application Discovery → Mapping → Security Testing → Vulnerability Identification → Controlled Validation → Risk Analysis → Remediation → Re-Testing → Reporting

This is an authorized educational security assessment. No public or third-party web application may be tested.

2. Problem Statement

Organizations increasingly depend on web applications to provide services to users.

Security weaknesses in web applications may allow unauthorized users to access information, bypass security controls, manipulate application behavior, or perform actions beyond their intended privileges.

A structured application-security assessment can identify such weaknesses before they are introduced into a production environment.

This project aims to demonstrate how a security professional can assess an intentionally vulnerable web application, document security weaknesses, analyze their impact, and recommend appropriate security controls.

3. Project Objectives

The student group must:

1. Deploy an intentionally vulnerable web application.
2. Configure an isolated web-security laboratory.
3. Identify the application's exposed services.
4. Identify the technologies used by the application.
5. Map important application functionality.
6. Identify potential security weaknesses.
7. Perform controlled security testing.
8. Validate selected vulnerabilities in the authorized laboratory.

9. Analyze the security impact of identified vulnerabilities.
10. Recommend appropriate remediation.
11. Perform re-testing where remediation is implemented.
12. Document technical evidence.
13. Prepare a professional web-application security assessment report.
14. Present and defend the project during the practical demonstration and viva.

4. Project Scope

4.1 Included in Scope

The project may include:

- Web-server identification
- Network/service assessment
- Web technology identification
- Application mapping
- Authentication assessment
- Authorization/access-control assessment
- Input-validation assessment
- Security-configuration assessment
- Selected OWASP-related security testing
- Vulnerability documentation
- Risk analysis
- Controlled validation
- Remediation recommendations
- Re-testing

4.2 Out of Scope

The following activities are outside the project scope:

- Testing public websites
- Testing college websites without written authorization
- Testing company websites

- Testing government websites
- Testing third-party applications
- Denial-of-service testing
- Destructive testing
- Malware deployment
- Attacking real user accounts
- Stealing real user information

All testing must remain within the intentionally vulnerable laboratory application.

5. Laboratory Environment

The minimum laboratory should contain:

System	Role
Kali Linux	Security assessment system
Ubuntu Server / equivalent	Web application server
OWASP Juice Shop / DVWA / WebGoat	Vulnerable application
VMware Workstation	Virtualization platform

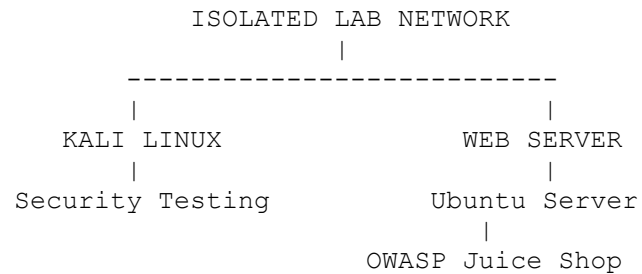
Optional:

- Windows 10/11
- Wireshark
- Nmap
- Burp Suite Community Edition
- Nikto
- OWASP ZAP
- Browser developer tools

The final selection of tools should be approved by the project guide.

6. Proposed Laboratory Architecture

A recommended architecture is:



Example addressing:

Kali Linux
192.168.60.10

Web Server
192.168.60.20

The addresses are examples only.

Students must document the actual IP addresses used.

The web application must be accessible only within the authorized laboratory environment.

7. Group Responsibilities

Each group contains three students.

The project is shared, but technical responsibilities are divided.

Student 1 — Web Reconnaissance and Application Mapping

Responsible for:

- Laboratory setup
- Web-server identification

- Port/service identification
- Technology identification
- Application mapping
- Application attack-surface documentation

Student 2 — Web Vulnerability Assessment and Validation

Responsible for:

- Vulnerability identification
- Security testing
- Evidence collection
- Risk analysis
- Controlled validation
- Vulnerability register

Student 3 — Security Analysis, Remediation and Re-Testing

Responsible for:

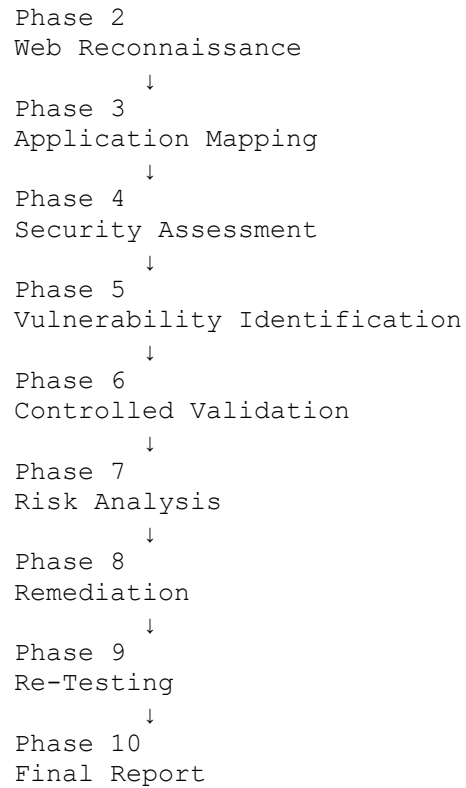
- Security-impact analysis
- Remediation recommendations
- Security configuration improvements where practical
- Re-testing
- Before/after comparison
- Final security analysis

All three students must understand the complete project and participate in the final presentation.

8. Project Methodology

The project must follow these phases:

Phase 1
Laboratory Preparation
↓



9. Phase 1 — Laboratory Preparation

Deploy the intentionally vulnerable web application.

The student must configure:

- Web server
- Application
- Network
- Application access
- Testing machine

Document:

- Operating system
- Web-server software
- Application name/version
- IP address
- Network configuration
- Application URL within the lab
- Hardware/VM configuration

Required Evidence

Include screenshots showing:

1. Virtual machines.
2. Web server.
3. Application running.
4. Kali Linux.
5. Network configuration.
6. Application access from the testing system.

10. Phase 2 — Web Reconnaissance

Identify the web application and its exposed services.

The student must investigate:

- IP address
- Open ports
- Web service
- Web-server technology
- Application technology
- Available protocols
- Security-relevant information exposed by the application

Prepare an application asset table.

Asset	IP Port	Service	Technology	Purpose
Web Server				
Application				

11. Phase 3 — Application Mapping

Map the major functions of the application.

Identify, where applicable:

- Login
- Registration
- User profile
- Search
- Product/content pages
- Administrative functionality
- API endpoints
- Forms
- File-upload functionality
- Other application functions

The student must create an application map.

Example:

```

Web Application
|
+---- Login
|
+---- Registration
|
+---- User Profile
|
+---- Search
|
+---- Products
|
+---- Administration

```

|
+----- APIs

The actual application structure must be based on the student's laboratory.

12. Phase 4 — Security Assessment

Perform a structured assessment of the application.

Students should consider appropriate OWASP-related security areas.

Potential areas include:

- Authentication
- Authorization
- Access control
- Input validation
- Injection
- Cross-site scripting
- Security misconfiguration
- Session security
- Sensitive information exposure
- Vulnerable components

Students do not need to demonstrate every OWASP category.

The assessment must be based on the actual capabilities of the laboratory application.

13. Phase 5 — Vulnerability Identification

Document identified vulnerabilities professionally.

Each finding must contain:

Vulnerability Finding

Finding ID: WEB-VUL-001

Affected Component: _____

URL/Endpoint: _____

Vulnerability: _____

Description: _____

Evidence: _____

Potential Impact: _____

Severity: _____

Recommendation: _____

Remediation Status: _____

14. Vulnerability Register

Create a consolidated vulnerability register.

ID	Component	Vulnerability	Severity	Impact	Recommendation	Status
WEB-VUL-001						
WEB-VUL-002						
WEB-VUL-003						
WEB-VUL-004						
WEB-VUL-005						

The severity must be justified using technical reasoning.

Students should not simply copy a severity rating from a tool without understanding it.

15. Phase 6 — Controlled Technical Validation

Select appropriate vulnerabilities and validate them within the intentionally vulnerable laboratory application.

Examples of suitable educational validation may include:

- Demonstrating an input-validation weakness
- Demonstrating an access-control weakness
- Demonstrating an authentication weakness
- Demonstrating a controlled injection vulnerability
- Demonstrating a controlled cross-site scripting vulnerability

The exact tests must depend on the deployed application.

For every validation, document:

1. Target
2. Vulnerability
3. Test objective
4. Method
5. Evidence
6. Result
7. Security impact
8. Recommended remediation

No real user information or third-party systems may be involved.

16. Phase 7 — Authentication and Access-Control Assessment

The group must specifically investigate application authentication and authorization.

Where supported by the laboratory, assess:

Authentication

- Login functionality
- Password handling
- Authentication behavior
- Session handling
- Logout behavior

Authorization

Determine whether users can access functions or information outside their intended privileges.

The testing must remain within the deliberately vulnerable application.

Document:

Expected Behavior → Observed Behavior → Security Impact → Recommendation

17. Phase 8 — Security Configuration Assessment

Review the web application and server for security-configuration issues.

Examples:

- Unnecessary exposed services
- Missing security headers
- Insecure server configuration
- Unnecessary information disclosure
- Insecure application settings
- Outdated components where applicable

Document each observation and its security significance.

18. Phase 9 — Risk Analysis

Analyze each major finding.

The analysis should consider:

- Affected component
- Likelihood
- Potential impact
- Exploitability
- Exposure
- Security consequence

Prepare a risk register.

Finding	Likelihood	Impact	Overall Risk	Priority
WEB-VUL-001				
WEB-VUL-002				
WEB-VUL-003				

19. Phase 10 — Remediation

For each important vulnerability, provide an appropriate remediation recommendation.

Where the laboratory permits actual remediation, implement the control.

Examples include:

- Input validation
- Parameterized queries
- Secure authentication controls
- Access-control enforcement
- Security headers
- Secure configuration
- Software updates
- Removal of unnecessary functionality
- Improved session management

The student must distinguish between:

Recommended Remediation

and

Remediation Actually Implemented

Do not claim that a vulnerability was fixed if the student only provided a recommendation.

20. Phase 11 — Re-Testing

After implementing remediation, repeat the relevant test.

Prepare a before/after table.

Finding	Initial Result	Remediation	Re-Test Result	Status
WEB-VUL-001				
WEB-VUL-002				
WEB-VUL-003				

The student must provide evidence supporting the final status.

21. Minimum Technical Deliverables

The group must complete the following minimum requirements.

Laboratory

- Kali Linux configured
- Web server configured
- Intentionally vulnerable web application deployed
- Isolated network configured
- Application accessible within the lab

Reconnaissance

- Web-server identification
- Port/service identification
- Technology identification
- Application mapping

Security Assessment

Minimum:

- **5 documented application-security findings**, where the selected laboratory application supports sufficient findings
- **2 controlled technical validations**

Security Analysis

Each major finding must include:

- Description
- Evidence
- Impact
- Severity
- Recommendation

Remediation

The group must provide remediation recommendations for all major findings.

Where technically feasible, at least **2 findings should be remediated or mitigated within the laboratory.**

Re-Testing

At least **2 remediated findings must be re-tested.**

Documentation

Submit:

- Technical report

- Presentation
- Architecture diagram
- Original screenshots
- Technical evidence
- Practical demonstration
- Individual contribution records

22. Measurable Learning Outcomes

After completing this project, students should be able to:

LO1 — Web Laboratory Deployment

Deploy and demonstrate an intentionally vulnerable web application in an isolated environment.

Measurement: Working application demonstrated from the authorized testing machine.

LO2 — Web Reconnaissance

Identify the web application's exposed services and technologies.

Measurement: Produce a documented service and technology inventory.

LO3 — Application Mapping

Identify and document major application functions and attack surfaces.

Measurement: Produce an application map supported by laboratory evidence.

LO4 — Web Security Assessment

Perform structured security testing against an authorized application.

Measurement: Document at least five supported security findings.

LO5 — Vulnerability Validation

Validate selected application-security findings.

Measurement: Demonstrate at least two controlled validations with evidence.

LO6 — Risk Analysis

Analyze the security impact of identified vulnerabilities.

Measurement: Produce a vulnerability/risk register containing evidence, impact, severity, and recommendations.

LO7 — Remediation

Recommend and, where technically feasible, implement application-security controls.

Measurement: Demonstrate at least two remediation/mitigation activities.

LO8 — Security Validation

Determine whether remediation was effective.

Measurement: Re-test at least two remediated findings and provide before/after evidence.

LO9 — Professional Documentation

Prepare a structured web-application security assessment report.

Measurement: Submit a complete, reproducible technical report.

LO10 — Technical Communication

Explain application-security concepts and project results.

Measurement: Successfully complete group presentation and individual viva.

23. Required Report Structure

The report must follow the standardized college project structure.

Chapter 1 — Introduction

1.1 Background

1.2 Problem Statement

1.3 Project Motivation

1.4 Objectives

1.5 Scope

1.6 Limitations

Chapter 2 — Existing System and Proposed Approach

2.1 Existing Security Situation

2.2 Security Problems

2.3 Proposed Assessment Approach

2.4 Expected Improvements

Chapter 3 — Requirements and Laboratory Environment

3.1 Hardware Requirements

3.2 Software Requirements

3.3 Virtual Machines

3.4 Network Configuration

3.5 Web Application

3.6 Tools

3.7 IP Addressing

3.8 Architecture

Chapter 4 — Methodology

4.1 Assessment Methodology

4.2 Web Reconnaissance

4.3 Application Mapping

4.4 Security Testing

4.5 Vulnerability Assessment

4.6 Controlled Validation

4.7 Remediation

4.8 Re-Testing

Chapter 5 — Implementation

5.1 Laboratory Setup

5.2 Web Application Deployment

5.3 Network Configuration

5.4 Security Assessment Configuration

5.5 Evidence Collection

Chapter 6 — Security Assessment and Analysis

6.1 Application Assessment Results

6.2 Vulnerability Findings

6.3 Technical Evidence

6.4 Risk Analysis

6.5 Security Impact

Chapter 7 — Security Remediation

7.1 Recommended Controls

7.2 Controls Implemented

7.3 Configuration/Application Changes

7.4 Security Improvements

Chapter 8 — Testing and Validation

8.1 Initial Results

8.2 Remediation

8.3 Re-Testing

8.4 Before/After Comparison

8.5 Final Results

Chapter 9 — Results and Discussion

9.1 Results

9.2 Analysis

9.3 Objective Achievement

9.4 Technical Challenges

9.5 Lessons Learned

Chapter 10 — Conclusion and Future Scope

10.1 Conclusion

10.2 Limitations

10.3 Future Improvements

10.4 Future Scope

References

Use appropriate technical references, OWASP documentation, official tool documentation, books, and other academic resources.

Appendix

Include:

- Relevant commands

- Tool output
- Configuration
- Screenshots
- Logs
- Technical evidence
- Additional tables

24. Mandatory Technical Evidence

The report must contain original evidence from the group's own laboratory.

Minimum evidence should include:

1. Web application deployment
2. Network architecture
3. IP configuration
4. Web-server/service identification
5. Technology identification
6. Application mapping
7. Vulnerability evidence
8. Controlled validation evidence
9. Authentication/access-control assessment evidence
10. Security-configuration assessment
11. Remediation evidence where implemented
12. Re-testing evidence
13. Final results

Every screenshot must include:

Figure Number + Caption + Explanation

Example:

Figure 6.3 — Web application technology identification performed against the authorized laboratory server

Screenshots copied from the Internet or another group will not be accepted.

25. Group Presentation Requirements

Prepare a **12–15 slide presentation**.

Recommended structure:

1. Project Title
2. Introduction
3. Problem Statement
4. Objectives
5. Scope
6. Laboratory Architecture
7. Web Application
8. Tools and Technologies
9. Methodology
10. Application Mapping
11. Major Vulnerability Findings
12. Security Impact
13. Remediation
14. Re-Testing and Results
15. Conclusion and Future Scope

Each student must present their assigned technical component.

26. Practical Demonstration

The group must demonstrate the working project.

The evaluator may ask the group to demonstrate:

1. Laboratory architecture
2. Web application
3. Network connectivity
4. Web-server identification
5. Application mapping

6. Selected vulnerability
7. Controlled validation
8. Security evidence
9. Remediation
10. Re-testing

The evaluator may select any student to demonstrate their assigned component.

27. Individual Responsibilities

Although the report is submitted as one group project, each student must maintain an individual contribution record.

Student 1

Responsible for:

Web Reconnaissance + Application Mapping

Must demonstrate:

- Service identification
- Technology identification
- Application mapping
- Attack-surface analysis

Student 2

Responsible for:

Vulnerability Assessment + Controlled Validation

Must demonstrate:

- Vulnerability identification
- Evidence collection

- Risk analysis
- Controlled validation

Student 3

Responsible for:

Remediation + Re-Testing

Must demonstrate:

- Security recommendations
- Remediation
- Validation
- Before/after comparison

28. Viva Questions

Students should be prepared to answer:

1. What is web application security?
2. What is OWASP?
3. Why is OWASP relevant to this project?
4. What is the difference between network security and application security?
5. What is authentication?
6. What is authorization?
7. What is broken access control?
8. What is input validation?
9. What is injection?
10. What is cross-site scripting?
11. What is session management?
12. What is security misconfiguration?
13. What is a vulnerability?
14. What is an exploit?
15. What is risk?
16. How did you identify your findings?

17. What evidence supports your findings?
18. Why did you assign a particular severity?
19. How did you validate your selected vulnerability?
20. What remediation did you recommend?
21. Which vulnerabilities did you actually remediate?
22. How did you perform re-testing?
23. How did you verify that remediation was successful?
24. What would you change before deploying the application to production?
25. What was your individual contribution to the project?

29. Evaluation Scheme

Component	Marks
Problem definition	5
Laboratory/application deployment	10
Reconnaissance & application mapping	10
Security assessment	15
Vulnerability analysis	15
Controlled validation	10
Remediation	10
Re-testing & validation	10
Documentation	5
Presentation & Viva	10
Total	100

30. Project Completion Criteria

The project will be considered complete only when the group demonstrates:

Working web-security laboratory

-

Application mapping

-

Documented security assessment

-

Minimum supported vulnerability findings

-

Controlled validation

-

Risk analysis

-

Remediation

-

Re-testing

-

Technical evidence

-

Professional documentation

-

Practical demonstration

-

Individual viva

A report consisting primarily of copied theory, generic OWASP descriptions, or screenshots from the Internet will not be considered a completed technical project.

31. Ethical and Security Requirements

This project is an authorized educational security assessment.

Students may test only the intentionally vulnerable application deployed in their assigned laboratory.

Students must not test public or third-party websites or applications.

No real user information should be collected or used.

No destructive testing or denial-of-service testing is permitted.

The objective is to learn how application-security professionals identify and remediate vulnerabilities in a controlled environment.

32. Final Submission Checklist

Before submitting, verify:

- Web-security laboratory configured
- Kali Linux configured
- Vulnerable web application deployed
- Network architecture completed
- IP addressing documented
- Web-server identification completed
- Technology identification completed
- Application mapping completed
- Security assessment completed
- Vulnerability findings documented

- Two controlled validations completed
- Risk analysis completed
- Authentication/access-control assessment completed
- Security configuration assessment completed
- Remediation recommendations completed
- At least two remediation/mitigation activities completed where feasible
- Re-testing completed
- Before/after comparison completed
- Original screenshots included
- Individual contribution documented
- Technical report completed
- Presentation completed
- Practical demonstration prepared
- Individual viva prepared

Project Code: CS-02

Project Type: Group Project — 3 Students

Submission: Technical Report + Presentation + Practical Demonstration + Individual Viva